

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by a decorative border containing the text 'CONIMBRIC' and 'SITATIS'. The seal is rendered in a light blue color.

Security Auditing

Lesson#8

Other important regulations: NIS2, GDPR

School Year 2025/2026

Master in Informatic Security (MSI)

Master in Informatic Engineering

Informatics Engineering Department

University of Coimbra



Learning Objectives

By the end of this class, students should be able to:

- Explain the purpose and scope of NIS2.
- Identify key obligations for organizations under NIS2.
- Understand the core principles and requirements of the GDPR.
- Recognize the relevance of GDPR to cybersecurity practices.



Agenda

1. Introduction to NIS2
 1. Background and Evolution
2. NIS2 Requirements and Compliance
 1. Core Security Measures
 2. Roles and Responsibilities
3. Auditing and Enforcement Under NIS2
 1. Legal and Financial Consequences



Introduction to NIS2

1.1 Background and Evolution

Why was NIS2 introduced?

- ✓ Cyberattacks on critical infrastructure have increased.
- ✓ NIS1 was inconsistently applied across EU member states.
- ✓ Stronger enforcement was needed to improve resilience.

🛑 What kind of cyber threats is the EU under?

Let's analyze the Consilium information on this topic:

<https://www.consilium.europa.eu/en/policies/top-cyber-threats/>

Additional info: ENISA Threat Landscape: <https://www.enisa.europa.eu/topics/cyber-threats/threat-landscape>



Introduction to NIS2

1.1 Background and Evolution

The Need for an Update: Why Was NIS2 Introduced?

NIS1 (2016) Challenges:

- ✗ Limited sector coverage – Only critical infrastructure (finance, energy, transport).
- ✗ Inconsistent enforcement – Each EU country implemented it differently.
- ✗ Weak penalties – No real incentive for compliance.
- ✗ No supply chain security requirements – Vendors and suppliers were a major attack vector.
- ✗ Unclear incident reporting rules – No strict deadlines for reporting breaches.



Introduction to NIS2

1.1 Background and Evolution

Brief comparison between NIS1 and NIS2

Feature	NIS1 (2016)	NIS2 (2022)
Sector Coverage	Only critical sectors (energy, transport, banking)	More sectors (food, healthcare, public administration, space, etc.)
Incident Reporting	No strict deadline	24h early warning, full report within 72h
Supply Chain Security	Not included	Mandatory risk management for suppliers
Penalties	Weak enforcement	Fines up to €10M or 2% of global turnover
Management Accountability	Not clearly defined	Executives personally liable
National Enforcement	Different rules per country	Executives personally liable



Introduction to NIS2

1.2 Scope and Key Changes in NIS2

Expansion of Sectors Covered

✓ NIS2 covers the following services:

CRITICAL

- Energy
- Transportation
- Healthcare
- Drinkable water
- Airspace
- Financial Infrastructure
- Banks
- Digital Infrastructure
- Not drinkable water
- IT Management Systems

IMPORTANT

- Postal Services
- Food
- Waste Management
- Digital Services Suppliers
- Manufacturers
- Chemical Industry



Introduction to NIS2

1.2 Scope and Key Changes in NIS2

New Risk Management and Reporting Requirements

- ✓ Conduct regular risk assessments 🔍
- ✓ Implement multi-factor authentication 🔑
- ✓ Report incidents within 24 hours ⌚



Introduction to NIS2

1.2 Scope and Key Changes in NIS2

Stricter Enforcement and Penalties

- What happens if companies don't comply?
- 🚨 Fines up to €10M or 2% of global turnover
- 🚨 Temporary bans from operating in the EU
- 🚨 Management held personally accountable



NIS2 Requirements and Compliance

2.1 Core Security Measures

Under Article 21 of NIS2, organizations must implement technical, operational, and organizational measures to manage cyber risk.

✓ 1. Risk-Based Security Management

Continuous risk assessments

Identification of network/system vulnerabilities

Security policies for data protection and system integrity



NIS2 Requirements and Compliance

2.1 Core Security Measures

Under Article 21 of NIS2, organizations must implement technical, operational, and organizational measures to manage cyber risk.

✓ 2. Supply Chain Security

Evaluate and mitigate risks from third-party suppliers

Contracts must define cybersecurity expectations

Continuous vendor risk assessment



NIS2 Requirements and Compliance

2.1 Core Security Measures

Under Article 21 of NIS2, organizations must implement technical, operational, and organizational measures to manage cyber risk.

✓ 3. Multi-Factor Authentication (MFA)

Required for remote access and critical operations

MFA policies must be standardized

Must cover both users and system administrators



NIS2 Requirements and Compliance

2.1 Core Security Measures

Under Article 21 of NIS2, organizations must implement technical, operational, and organizational measures to manage cyber risk.

✓ 4. Incident Reporting

24 hours for early warning to the national CSIRT or competent authority

Full report within 72 hours

Final assessment within 1 month



NIS2 Requirements and Compliance

2.1 Core Security Measures

Under Article 21 of NIS2, organizations must implement technical, operational, and organizational measures to manage cyber risk.

✓ 4. Incident Reporting

24 hours for early warning to the national CSIRT or competent authority

Full report within 72 hours

Final assessment within 1 month



NIS2 Requirements and Compliance

2.1 Core Security Measures

Who does NIS2 applies to?

① Essential Entities (EE)

 Examples:

Energy (electricity, gas, oil)

Healthcare (hospitals, clinics)

Transport (air, rail, water, road)

Finance and banking

Drinking water & wastewater

Digital infrastructure (IXPs, DNS, cloud services)

Public electronic communications networks



Must implement all NIS2 requirements with highest scrutiny.



NIS2 Requirements and Compliance

2.1 Core Security Measures

Who does NIS2 applies to?

② Important Entities (IE)

 Examples:

Postal and courier services

Waste management

Chemicals, food production

Manufacturing of medical devices and electronics

Research organizations

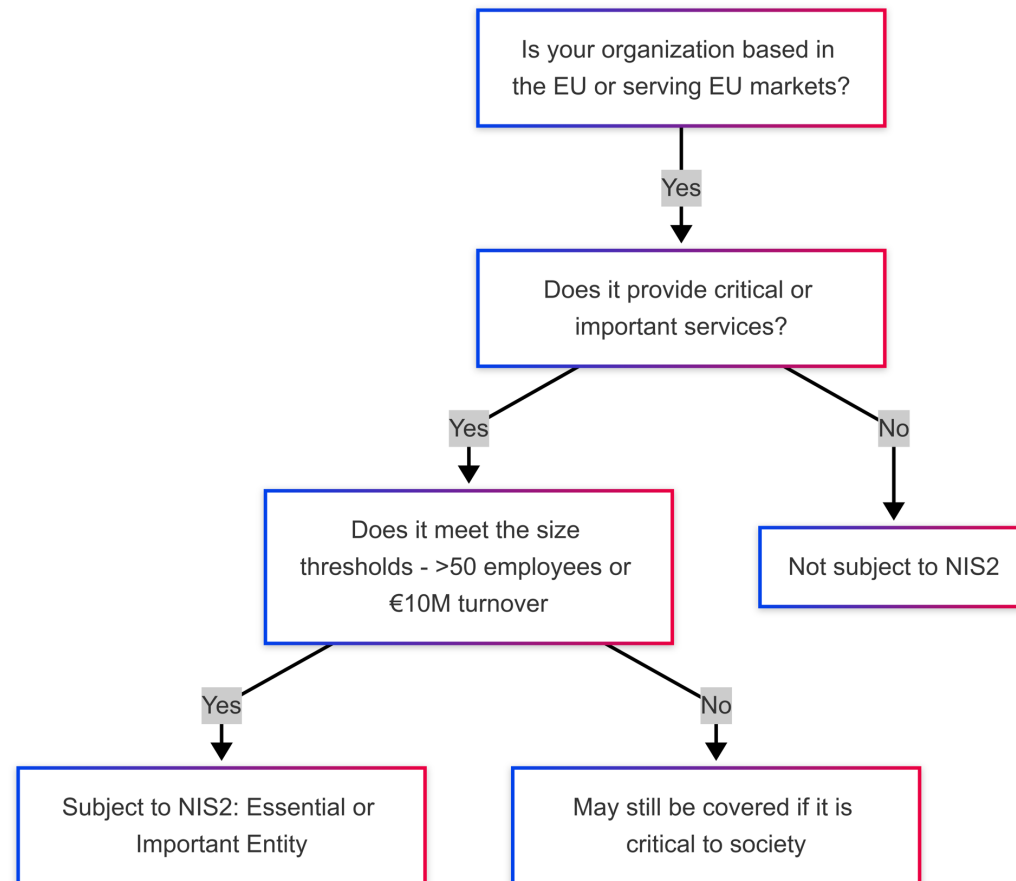
Digital service providers (marketplaces, search engines)

 Subject to audits, but with lower supervision intensity unless they pose a critical risk.

NIS2 Requirements and Compliance

2.1 Core Security Measures

Is NIS2 applicable to your organization?





NIS2 Requirements and Compliance

2.2 Roles and Responsibilities

- Who's responsible under NIS2?

1. Essential and Important Entities (Operators)

These are **organizations covered by NIS2**, and their responsibilities include:

-  **Implementing appropriate technical and organizational measures**
-  **Reporting incidents** to national authorities within required timeframes
-  **Maintaining risk management practices**, including supply chain security
-  **Conducting regular security audits**



NIS2 Requirements and Compliance

2.2 Roles and Responsibilities

- Who's responsible under NIS2?

2. Senior Management & Board Members

Under NIS2, **executives are accountable** for cybersecurity decisions:

-  Must **approve and oversee** security risk management measures
-  Must receive **basic cybersecurity training**
-  May be held **personally liable** in the event of negligence or non-compliance



NIS2 Requirements and Compliance

2.2 Roles and Responsibilities

- Who Ensures Compliance?

National Competent Authorities (NCAs)

Each EU member state designates one or more NCAs to:

-  **Monitor compliance** and conduct inspections or audits
-  **Impose penalties** for non-compliance
-  Serve as the **first point of contact** for incident reporting

Auditing and Enforcement Under NIS2

3.1 Legal and Financial Consequences

Enforcement Mechanisms

- Under Articles 32–37, enforcement is not just symbolic—it's real and financially significant.

Consequence	Details
 Financial Penalty	Up to €10M or 2% of global annual turnover (whichever is higher)
 Operational Restrictions	Temporary or permanent ban from providing services in the EU
 Personal Liability	Executives and board members can be held directly accountable

 Authorities can conduct inspections, request documents, and require corrective action.



Agenda

1. Historical Background and Scope of the GDPR
2. GDPR Core Concepts and Principles
3. Security Requirements Under the GDPR
4. Enforcement and Penalties



Introduction to GDPR

1. Historical Background and Scope

Key Milestones in EU Data Protection

1. **1980**: OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal Data
2. **1995**: EU Data Protection Directive (95/46/EC)
 1. Harmonized data protection laws across EU Member States
 2. Established key concepts like “personal data” and “data processing”
3. **2012**: Initial GDPR Proposal by the European Commission
4. **2016**: GDPR adopted; 2-year transition period
5. **25 May 2018**: GDPR enforcement date



Introduction to GDPR

1. Historical Background and Scope

From Directive 95/46/EC to GDPR

- **Directive** 95/46/EC
 - Required transposition into national law (leading to some variations across Member States).
 - Provided a foundation for modern data protection but did not account fully for the digital age's challenges (social media, big data, cloud computing).
- General Data Protection **Regulation** (GDPR)
 - Directly binding in all EU Member States, reducing legal fragmentation.
 - Introduced higher penalties and stronger individual rights.
 - Recognized rapid technological changes, reinforcing accountability and transparency.



Introduction to GDPR

1. Historical Background and Scope

From Directive 95/46/EC to GDPR

- **Directive** 95/46/EC

- Required transparency
- Provided a foundation for data protection (social media, big data)

- General Data Protection Regulation (GDPR)

- Directly binding
- Introduced higher standards

- Recognized rapid technological changes, reinforcing accountability and transparency.

GDPR Recital 6:

“Rapid technological developments and globalisation have brought new challenges for the protection of personal data. ... The scale of the collection and sharing of personal data has increased significantly.”

challenges



Introduction to GDPR

1. Historical Background and Scope

Scope of the GDPR – Overview

- Material Scope: What is “personal data” and “processing”

GDPR Article 2(1) (Material scope):

“This Regulation applies to the processing of personal data wholly or partly by automated means...”

- Territorial Scope: Does GDPR apply only in the EU or beyond?

GDPR Article 3(1) (Territorial scope):

“This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union...”



Introduction to GDPR

1. Historical Background and Scope

Material Scope – Personal Data & Processing

- Personal Data (Article 4(1))

- “Any information relating to an identified or identifiable natural person (‘data subject’).”
- Examples: Name, email, IP address (if linkable to an individual), location data, biometric data.

- Processing (Article 4(2))

“Any operation or set of operations ... such as collection, recording, organization, structuring, storage, adaptation ... disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.”



Introduction to GDPR

1. Historical Background and Scope

Territorial Scope – Extraterritorial Effect

- Article 3(1): GDPR applies to **controllers/processors** with an EU establishment.
- Article 3(2): GDPR applies to non-EU organizations if they:
 - Offer goods or services to **individuals** in the EU, or
 - Monitor the behavior of **individuals** in the EU (e.g., tracking cookies, targeted ads).

Excerpt (Article 3(2)):

“This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to ... the offering of goods or services ... or the monitoring of their behaviour...”



Introduction to GDPR

1. Historical Background and Scope

Why Extraterritorial?

–Protect EU Residents' Data

- Designed to prevent data protection loopholes when data flows outside EU borders.
- Acknowledges global nature of online transactions and services.

–Creating a Global Privacy Standard

- GDPR has influenced legislation in other jurisdictions (e.g., California Consumer Privacy Act).



Introduction to GDPR

1. Historical Background and Scope

Why Extraterritorial?

– Pros:

- Level playing field for EU-based and foreign companies.
- Stronger protections for EU residents wherever their data travels.

– Cons:

- Compliance challenges for smaller non-EU businesses.
- Possible conflicts with other jurisdictions' laws.



Introduction to GDPR

2. Core Concepts and Principles

Legal Bases for Processing (**only one** is needed)

- Consent (Article 6(1)(a)): Freely given, specific, informed, unambiguous. Right to withdraw at any time.
- Contract (Article 6(1)(b)): Processing necessary for the performance of a contract.
- Legal Obligation (Article 6(1)(c)): Required to comply with a legal mandate (e.g., tax laws).
- Vital Interests (Article 6(1)(d)): Protect someone's life (e.g., medical emergencies).
- Public Task (Article 6(1)(e)): Necessary for the public interest or in the exercise of official authority.
- Legitimate Interests (Article 6(1)(f)): Balancing test: interest of the controller vs. rights of data subjects.

Excerpt from GDPR (Article 6)

“Processing shall be lawful only if and to the extent that at least one of the following applies:
(a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes...”



Introduction to GDPR

2. Core Concepts and Principles

Data Protection Principles

- **Lawfulness:** Must have a valid legal basis.
- **Fairness:** No unfair or misleading practices.
- **Transparency:** Clear and concise communication to data subjects (e.g., privacy notices).
- **Purpose Limitation:** Data collected for a specified, explicit, and legitimate purpose. No further incompatible processing.
- **Data Minimization:** Collect only what is necessary for the stated purpose.

Excerpt (Article 5(1)(b-c))

“Personal data shall be collected for specified, explicit and legitimate purposes... adequate, relevant and limited to what is necessary...”



Introduction to GDPR

2. Core Concepts and Principles

Data Protection Principles

- **Accuracy:** Keep data up to date; rectify or erase inaccurate data.
- **Storage Limitation:** Keep data in a form that permits identification only as long as needed.
Implement retention policies.
- **Integrity & Confidentiality:** Protect against unauthorized access, loss, or damage. Enforce security measures (encryption, access controls).

Excerpt (Article 5(1)(e-f))

“Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary... [and] processed in a manner that ensures appropriate security...”



Introduction to GDPR

2. Core Concepts and Principles

Data Protection Principles

- **Accountability:** Organizations must demonstrate compliance with all principles, maintain documentation (policies, procedures, training records). Regularly review and update data protection measures.

Excerpt (Article 5(1)(e-f))

“Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary... [and] processed in a manner that ensures appropriate security...”



Introduction to GDPR

2. Core Concepts and Principles

Key Roles

Data Subjects: the owner of the data, over which has rights.

Data Controllers: An entity that determines the purposes and means of processing personal data and is responsible for compliance.

Data Processors: An entity that processes personal data on behalf of the controller, following the controller's instructions and contractual obligations.

Data Protection Officer (DPO): A professional overseeing an organization's data protection strategy and ensuring GDPR compliance, maintaining independence and expertise in privacy matters.



Introduction to GDPR

2. Core Concepts and Principles

Data Subject Rights

- The GDPR grants individuals (data subjects) a set of enforceable rights.
- Organizations (controllers) must enable and comply with these rights.
- Rights are designed to give individuals control over their personal data.

Excerpt (Article 12(2)):

“The controller shall facilitate the exercise of data subject rights under Articles 15 to 22.”

Key Point:

- Controllers must have processes in place to honor requests and communicate outcomes clearly and promptly (usually within one month).



Introduction to GDPR

2. Core Concepts and Principles

Data Subject Rights

Right	GDPR Article	Description
Right to be Informed	Art. 12–14	Clear, transparent info about how personal data is used.
Right of Access	Art. 15	Individuals can request copy of their personal data and info on how it's processed.
Right to Rectification	Art. 16	Correct inaccurate or incomplete personal data.
Right to be Forgotten	Art. 17	Request deletion of personal data when no longer needed or if consent withdrawn.
Right to Restrict Processing	Art. 18	Temporarily “freeze” processing in certain circumstances (e.g., pending accuracy checks).
Right to Data Portability	Art. 20	Receive personal data in a commonly used, machine-readable format ; transfer it to another controller.
Right to Object	Art. 21	Object to processing based on legitimate interests or direct marketing.
Rights in relation to Automated Decision-Making	Art. 22	Request human intervention in significant decisions made solely by automated means (e.g., credit scoring).



Introduction to GDPR

3. Security Requirements Under the GDPR

Examples of Security Measures

Common Technical Measures

- **Encryption:** Protecting data at rest and in transit.
- **Pseudonymization:** Replacing identifiable data with placeholders.
- **Access Controls:** Role-based permissions, multi-factor authentication.
- **Logging & Monitoring:** Tracking who accesses data, when, and why.

Organizational Measures

- **Data Protection Policies:** Clear guidelines for staff.
- **Incident Response Plans:** Define roles, procedures, and timelines.
- **Training & Awareness:** Ensuring employees understand security protocols.



Introduction to GDPR

3. Security Requirements Under the GDPR

Implementing the Data Subject Rights

1. Implementing Requests

- Identify data subject: robust verification process to ensure correct identity.
- Fulfillment Processes: Outline step-by-step procedures for each right (e.g., rectification queue, erasure requests).
- Records of Processing: Keep logs of how/when requests are addressed.

2. Timelines & Exceptions

- Respond within one month (may extend by two months for complex cases).
- Certain exceptions (e.g., ongoing legal obligations) may limit or override rights.

3. Technical & Organizational Measures

- Data mapping and classification help locate data quickly.
- Automated workflows can expedite request handling.



Introduction to GDPR

3. Security Requirements Under the GDPR

Breach Notification Obligations

Article 33: Notification to Supervisory Authority

- If a personal data breach occurs, the controller must notify the relevant authority within 72 hours of becoming aware.
- Must describe the nature of the breach, likely consequences, and measures taken or proposed.

Excerpt (GDPR Article 33(1)):

“In the case of a personal data breach, the controller shall without undue delay ... notify the personal data breach to the supervisory authority ... not later than 72 hours...”



Introduction to GDPR

3. Security Requirements Under the GDPR

Breach Notification Obligations

Article 34: Communication to Data Subjects

- Obligation to notify affected individuals if the breach is likely to result in a high risk to their rights and freedoms.
- Explanation of what happened, possible consequences, and steps taken to mitigate harm.

When is Notification to Data Subjects Not Required?

- If the data is protected (e.g., encrypted) or if risks are no longer likely to materialize.



Introduction to GDPR

4. Enforcement and Penalties

Regulatory Framework – Key Bodies

European Data Protection Board (EDPB)

- It comprises representatives from each EU Member State's Data Protection Authority (DPA).
- Guides interpreting the GDPR (e.g., issuing guidelines and recommendations).
- Coordinates enforcement actions to ensure consistent application across the EU.

National Data Protection Authorities (DPAs)

- One lead DPA in the Member State where the main establishment is located, plus local DPAs as needed.
- Investigate complaints, conduct audits, and impose penalties.
- Each Member State has its own DPA (e.g., CNIL in France, ICO in the UK—when still subject to GDPR rules, etc.).



Introduction to GDPR

4. Enforcement and Penalties

Penalties for Non-Compliance

Two-Tier Fine Structure

- Lower Tier
 - Up to 2% of global annual turnover or €10 million (whichever is higher).
 - Applied to breaches of certain administrative obligations (e.g., record-keeping, contract requirements).
- Higher Tier
 - Up to 4% of global annual turnover or €20 million (whichever is higher).
 - More severe violations (e.g., infringing on data subjects' rights and freedoms, breach of basic processing principles).



Introduction to GDPR

4. Enforcement and Penalties

More Than Just Fines: Reputational & Operational Impact

- Reputational Harm

- Publicity: Regulators often publish decisions, so negative press can impact brand trust.
- Customer Confidence: Data breaches or heavy fines can lead to loss of customers or market share.

- Operational Challenges

- Remediation Costs: Hiring new consultants, upgrading systems, retraining staff.
- Injunctions: DPAs can suspend data processing, causing major business disruptions.
- Legal Feuds: Potential litigation from affected data subjects or class-action suits.



Agenda

1. Digital Operational Resilience Act (DORA)
2. EU Cybersecurity Act
3. SOC2 Type II



Digital Operational Resilience Act (DORA)

Objectives:

- Understand DORA's motivation and scope.
- Learn key provisions for operational resilience.
- Recognize real-world implications and compliance challenges.

Work Plan:

1. Background and Purpose
2. Key Provisions
3. Practical Implications and Challenges



Digital Operational Resilience Act (DORA)

1. Background and Purpose

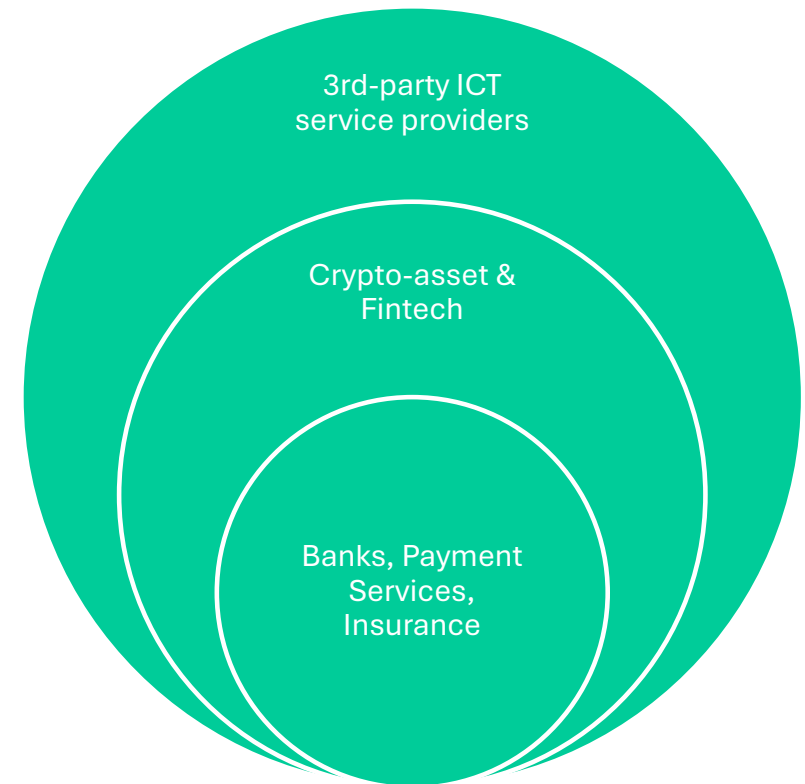
- Origins of DORA:
 - Drafted by the European Commission in response to rising digital threats in the financial sector.
 - Builds on existing initiatives like the NIS Directive, focusing on operational resilience.
- Drivers:
 - Surge in cyberattacks on financial entities.
 - Need for standardized resilience practices across EU financial markets.
 - Protecting consumers, markets, and the broader financial ecosystem.

Digital Operational Resilience Act (DORA)

1. Background and Purpose

Entities in Scope

- Which organizations are covered by DORA?
 - Traditional financial institutions: Banks, investment firms, payment institutions.
 - Crypto-asset service providers.
 - Third-party ICT service providers (e.g., cloud providers) supporting financial institutions.
- Potential Expansion:
 - FinTech start-ups, insurance companies, e-money institutions, and more.



Digital Operational Resilience Act (DORA)

2. Key Provisions

ICT Risk Management Requirements

- Governance and Oversight:
 - Boards and senior management must oversee ICT risk strategy.
- Risk Assessment:
 - Continuous identification, monitoring, and evaluation of ICT risks.
- Controls and Policies:
 - Establish and maintain policies for risk prevention, detection, and response.
- Third-Party Risk Management:
 - Contractual obligations, due diligence, monitoring of outsourced services.



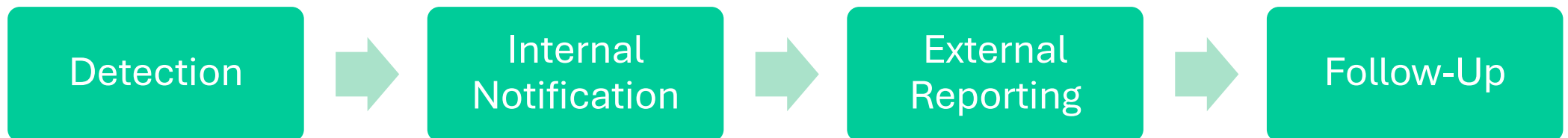


Digital Operational Resilience Act (DORA)

2. Key Provisions

Incident Reporting

- Reporting Thresholds:
 - Major incidents must be reported within a specific timeline (e.g., no later than the end of the next business day).
- Reporting Channels:
 - Designated authorities or supervisory bodies, potentially coordinated at the EU level.
- Incident Response Plans:
 - Mandatory internal procedures to handle cyber incidents swiftly.

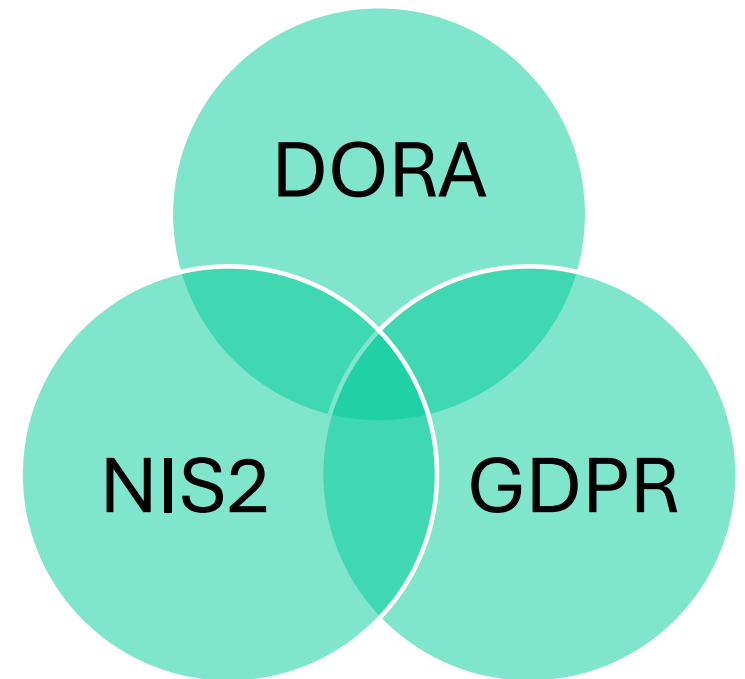


Digital Operational Resilience Act (DORA)

3. Practical Implications and Challenges

Synergies with other frameworks

1. Related EU Regulations: NIS2, GDPR, etc.
2. Overlap and Complementarity:
 - Data protection, operational resilience, and incident reporting.
 - Single integrated approach to reduce duplication of work (shared controls).
 - Leverage existing compliance structures.
3. Challenges:
 - Avoiding conflicting requirements.
 - Harmonizing compliance strategies.





EU Cybersecurity Act

Objectives

- Understand the legislative context and core goals of the EU Cybersecurity Act.
- Explore the major components, including ENISA's enhanced mandate and EU-wide certification schemes.
- Recognize the impact on organizations and the challenges/opportunities that arise.



EU Cybersecurity Act

Historical Context & ENISA's Evolution

- Earlier Cybersecurity Strategy
 - EU Cybersecurity Strategy (e.g., from 2013 and 2017 updates).
 - Initial focus on cooperation between EU member states.
- ENISA's Role (European Union Agency for Cybersecurity)
 - Established to facilitate cooperation and provide guidance on cyber threats.
 - Originally had a limited mandate, mostly advisory.

Why was ENISA created?

- Fill the gap of a central coordinating body at the EU level.

Shifts in Threat Landscape

- Rapid digitization and the surge in cyberattacks prompted more robust roles.

EU Cybersecurity Act

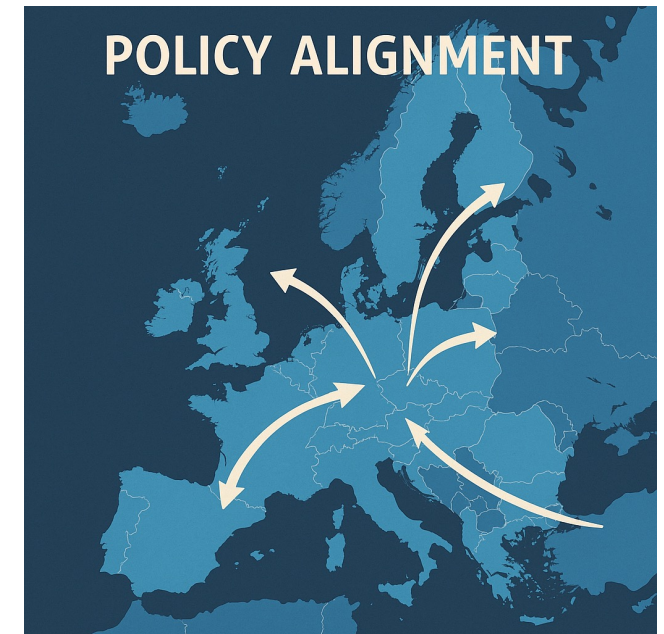
Scope & Objectives of the EU Cybersecurity Act

Scope:

- Applies across all sectors and industries, **not limited** to finance or critical infrastructure.
- Aims to **create a common cybersecurity baseline** for products, processes, and services throughout the EU.

Objectives:

- Strengthen **EU-wide frameworks** for cyber resilience.
- **Harmonize** certification processes.
- Increase **trust and transparency** in digital products/services.



EU Cybersecurity Act

Harmonizing Cybersecurity Certification Frameworks

Why?

Fragmentation in national approaches leads to confusion, complexity, and compliance burdens.

For what:

Provide consistent assurance about the security level of IT products/services, recognized across all EU member states.

Reducing duplicative audits and conflicting standards across different countries

Encouraging cross-border business by removing cybersecurity compliance barriers.



EU Cybersecurity Act

Enhanced Mandate for ENISA

Role in Coordinating Incident Response & Threat Intelligence

ENISA is now a central hub for exchanging threat intelligence and best practices.

Permanent Mandate:

No longer time-limited or requiring frequent renewals.

Adding Responsibilities:

Developing and implementing certification schemes.

Providing support to member states for incident response readiness.



EU Cybersecurity Act

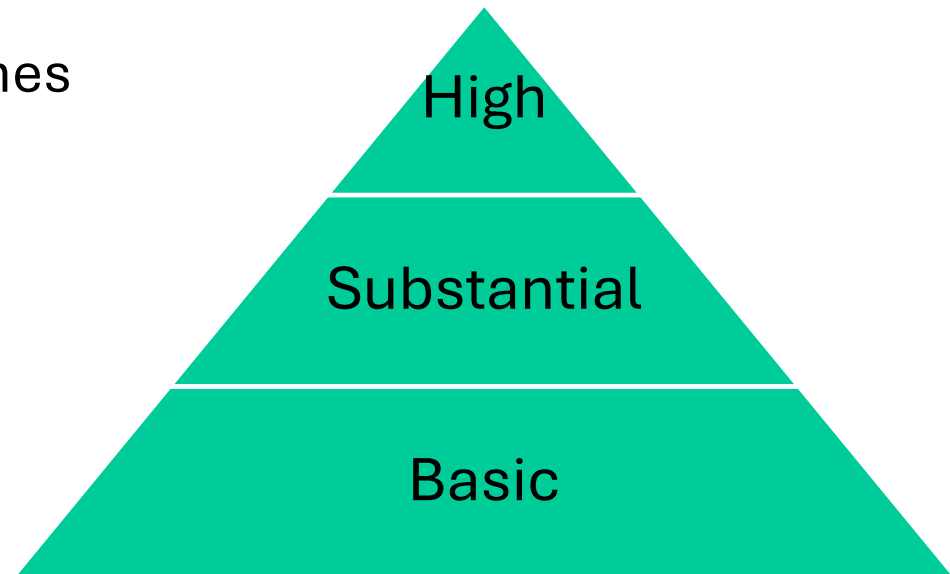
EU-Wide Cybersecurity Certification Schemes

Three Levels of Assurance:

1. Basic
2. Substantial
3. High

Voluntary vs. Mandatory:

- Currently, many certifications are voluntary.
- Possibility of certain schemes becoming mandatory for critical technologies/products in the future.
- Mutual Recognition: Once certified in one member state, recognized across the entire EU.





EU Cybersecurity Act

Stakeholder Responsibilities

Manufacturers & Service Providers

- Ensure products meet relevant certification schemes.
- Transparent disclosure of cybersecurity features/risks.

EU Member States

- Support and promote adoption of EU certification schemes.
- Collaborate with ENISA for incident response.

Consumers & End-Users

- Informed decisions based on certification labels.
- Role in responsible use and reporting vulnerabilities.

EU Cybersecurity Act

Impact on Organizations – Certification Requirements

Identifying Applicable Schemes:

- Organizations must determine which certification program suits their products/services.

Resource Allocation:

- Costs related to audits, compliance, and maintaining certifications.

Ongoing Compliance:

- Periodic renewals or updates if the product/service changes significantly.

CHECKLIST



EU Cybersecurity Act

Impact on Organizations – Market & Consumer Confidence

Competitive Advantage:

- EU certification can distinguish products/services in a crowded marketplace.

Transparency & Trust:

- Certified solutions signal higher security to customers.

Potential for Growth:

- Easier cross-border sales if recognized as compliant in all EU states.





EU Cybersecurity Act

Challenges & Opportunities

Challenges:

- Navigating multiple directives (e.g., NIS2, GDPR) + national laws.
- Resource-intensive certification process.
- Keeping pace with evolving technologies and threats.

Opportunities:

- Streamlined compliance via single EU certification recognized across member states.
- Potential leadership in setting global cybersecurity standards.
- Collaboration and knowledge-sharing across the EU.

SOC2 Type II

Objectives

- Understand the foundation and purpose of SOC 2.
- Differentiate between SOC 2 Type I and Type II.
- Explore the audit process and reporting.
- Recognize key benefits, challenges, and overlaps with other frameworks.





SOC2 Type II

1. Introduction to SOC2

History & Purpose

- Developed by: American Institute of Certified Public Accountants (AICPA).
- Purpose
 - Assess internal controls of service organizations (e.g., SaaS providers, data centers).
 - Provide assurance to clients regarding security and data protection practices.
 - SOC 2 evolved from the Statement on Auditing Standards (SAS) 70 and later the SSAE 16 environment, eventually leading to SSAE 18.
 - Primarily used by technology service organizations, but also relevant for a wide range of third-party providers handling sensitive data.

Why do you think a professional accounting body (AICPA) oversees this framework for IT controls, rather than a purely technical organization?



SOC2 Type II

1. Introduction to SOC2

Trust Services Criteria (TSC)

SOC 2 focuses on the five TSCs:

- Security (common to all SOC 2 reports)
- Availability
- Processing Integrity
- Confidentiality
- Privacy



SOC2 Type II

2. SOC2 Type II vs SOC2 Type I

- **Type I**

- Focuses on a point-in-time assessment of controls' design.
- Answers: “Are the controls appropriately designed as of a specific date?”

- **Type II:**

- Focuses on operating effectiveness of controls over a period (typically 3–12 months).
- Answers: “Are the controls functioning effectively on an ongoing basis?”

- **Why Type II is More Commonly Requested:**

- Demonstrates consistent, long-term adherence to control requirements.
- More rigorous and assures clients that controls are reliable over time.



SOC2 Type II

3. The Audit Process

Planning & Readiness

Scoping:

- Identify the boundaries (systems, processes, locations).
- Determine which TSCs apply.

Readiness Assessment:

- Gap analysis of existing controls vs. SOC 2 requirements.
- Document operational processes, policies, and procedures.
- Organizations often perform an internal readiness check to fix glaring issues before the formal audit begins.
- Proper planning mitigates audit surprises and reduces the risk of control failures.



SOC2 Type II

3. The Audit Process

Fieldwork & Testing

Evidence Gathering:

- Auditors review policies, system configurations, logs, and samples of transactions.

Interviews & Observation:

- Validate whether employees follow documented procedures.

Control Testing Methods

- **Inquiry** (asking questions), **Inspection** (reviewing documentation), **Observation** (watching processes in action), and **Re-performance** (testing the control as the organization would).



SOC2 Type II

3. The Audit Process

Reporting

SOC 2 Report Sections:

1. Management's assertion on the system and controls.
2. Auditor's opinion (unmodified, qualified, or adverse).
3. Description of controls and how they were tested.
4. Test results and any findings or exceptions.

User Considerations:

- Typically, a restricted-use report (intended for clients, not public).



SOC2 Type II

4. Organizational Benefits and Challenges

- **Enhanced Credibility:**

- Demonstrates commitment to security and best practices.

- **Trust with Clients:**

- Frequently a contractual requirement in B2B relationships (e.g., large enterprise clients).

- **Competitive Advantage:**

- Helps differentiate from competitors without a SOC 2 report.

NOTES:

- Market Demand: Many RFPs (Requests for Proposal) now require a SOC 2 Type II.
- Internal improvements: The process can tighten security posture and clarify responsibilities.